SİBER GÜVENLİK DERSİ

Hafta 2 ve Hafta 3 Ek Görev Raporu

Onur Alkan
Öğrenci No: 232923044
Tarih: 17 Ekim 2026

Kapsam: Parola kırma (Hashcat/John), TLS taraması (sslscan), PKI ve kontrollü MITM (mitmproxy)

Etik kapsam: Tüm işlemler yalnızca yerel laboratuvar ortamında, kendi üretilen özetler ve 127.0.0.1/lab.local hedefi üzerinde gerçekleştirilmiştir. Gerçek kişi parolası veya üçüncü taraf sistem kullanılmamıştır.

1. Laboratuvar Ortamı ve Yöntem

Çalışma, Kali Linux sanal makinesinde ve deney aşamalarında internet erişimi kapalı olacak şekilde yürütüldü. Hashcat'in CPU üzerinde çalışabilmesi için PoCL OpenCL çalışma zamanı kuruldu; ardından NAT bağlantısı kapatıldı ve yalnızca Host-only ağ bırakıldı.

- Kali Linux: 2026.2 tabanlı sistem (kernel 6.19.14+kali-amd64)
- Hashcat: v7.1.2
- OpenCL: PoCL 7.1, CPU cihazı: 12th Gen Intel(R) Core(TM) i7-1255U
- Sanal makine belleği: 4 GB (yaklaşık 3.8 GiB kullanılabilir)
- TLS taraması: sslscan 2.1.5 / OpenSSL 3.6.2
- MITM aracı: mitmproxy, 127.0.0.1:8080
- Laboratuvar alan adı: lab.local → 127.0.0.1

Sorun giderme: İlk Hashcat denemesinde 2 GB RAM ile "Not enough allocatable device memory" hatası alındı. VM belleği 4 GB'a çıkarıldıktan sonra aynı görevler başarılı biçimde tamamlandı.

2. Hafta 2 - Parola Kırma Uygulaması

Öğrenci numarası 232923044 ile görev betiği çalıştırılarak aynı sekiz parolanın MD5, SHA-256 ve bcrypt özetleri üretildi. Küçük ders sözlüğü (28 aday) ile sözlük saldırısı uygulandı. Üretilen ham özet dosyaları ve çözüm listeleri rapor dışında paylaşılmadı.

2.1 MD5

Hashcat MD5 modu (-m 0) ile sekiz özetin tamamı bulundu. Gerçek kırma oturumunda sonuç 8/8 (%100) olarak kaydedildi. Küçük sözlük nedeniyle bu oturumdaki anlık hız benchmark ile doğrudan karşılaştırılmamalıdır; karşılaştırma için Bölüm 2.4'teki benchmark değerleri kullanılmıştır.

```
Approaching final keyspace - workload adjusted.

e99a18c428cb38d5f260853678922e03:abc123
96e79218965eb72c92a549dd5a330112:111111
f25a2fc72690b780b2a14e140ef6a9e0:iloveyou
8afa847f50a716e64932d995c8e7435a:princess
eb0a191797624dd3a48fa681d3061212:master
9242789aefccfbb7361ce22e1e742307:istanbul34
599c5fbdfcd41e74927bddb9ca234b05:besiktas
23cf7c88944f1f210c5621b668980128:trabzon61

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 0 (MD5)
Hash.Target......: ekip_md5.txt
Time.Started.....: Sat Oct 17 13:59:09 2026 (1 sec)
Time.Estimated...: Sat Oct 17 13:59:10 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (ders_sozluk.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:      544 H/s (0.01ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered........: 8/8 (100.00%) Digests (total), 8/8 (100.00%) Digests (new
)
Progress.........: 28/28 (100.00%)
Rejected.........: 0/28 (0.00%)
Restore.Point....: 0/28 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 123456 -> qwerty123
Hardware.Mon.#01.: Util: 41%

Started: Sat Oct 17 13:59:05 2026
Stopped: Sat Oct 17 13:59:11 2026
```

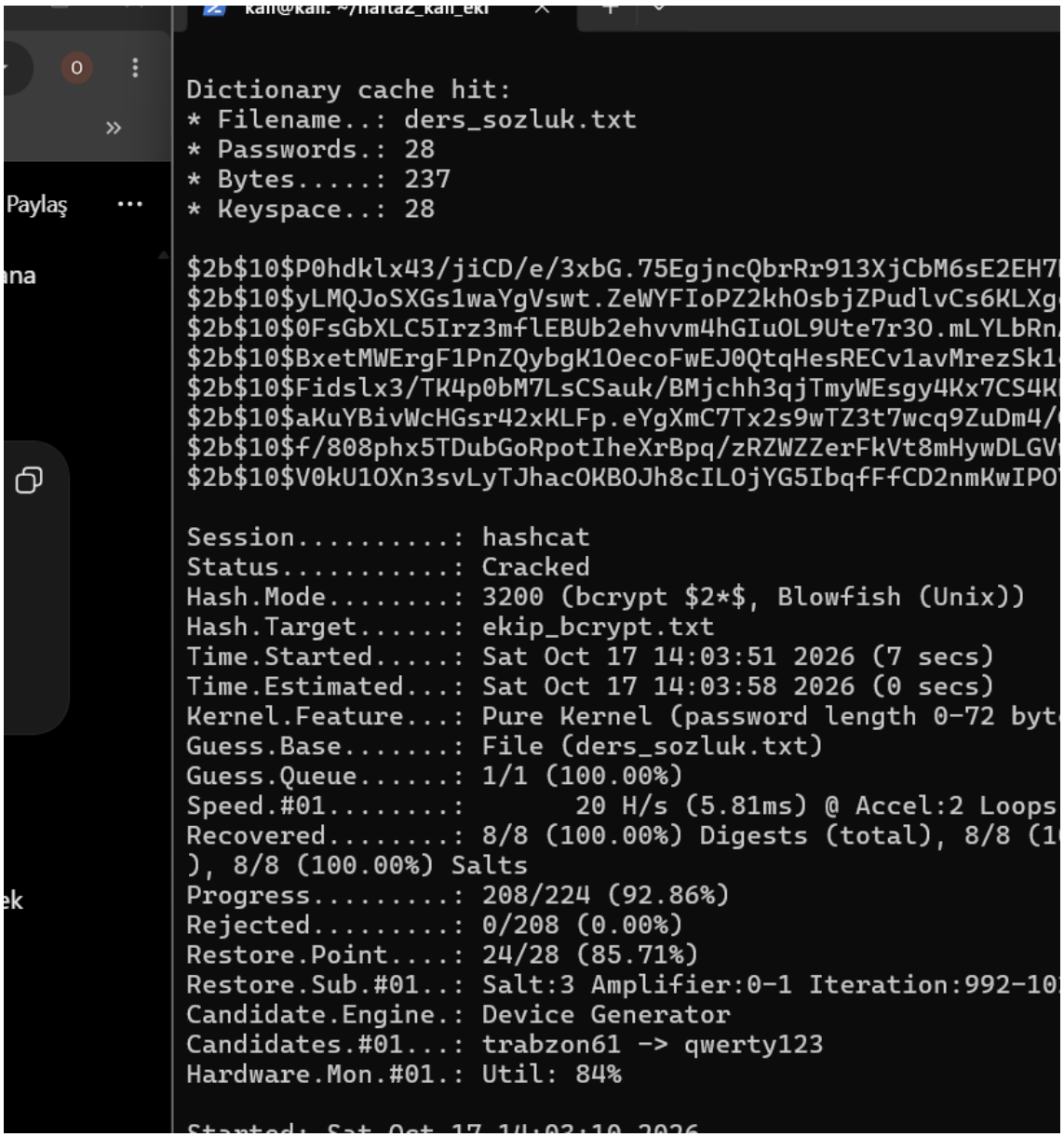
Şekil 1 - MD5 sözlük saldırısı: 8/8 özetin kırılması ve Hashcat durum çıktısı.

2.2 SHA-256

Hashcat SHA2-256 modu (-m 1400) ile aynı sekiz parola yine 8/8 oranında bulundu. Kırma oturumunda Speed.#01 = 78,599 H/s görüldü; bu değer küçük anahtar uzayı ve pure kernel koşullarına aittir. Esas karşılaştırma benchmark sonucudur.

2.3 bcrypt

Hashcat bcrypt modu (-m 3200) ile küçük sözlükteki sekiz parola yine bulundu; ancak deneme hızı belirgin biçimde düştü. Kırma oturumunda Speed.#01 = 20 H/s ve Recovered = 8/8 kaydedildi.



Şekil 2 - bcrypt sözlük saldırısı: 8/8 sonuç ve yaklaşık 20 H/s oturum hızı.

2.4 Benchmark Sonuçları

Algoritma	Hashcat modu	Benchmark hızı	Göreli değerlendirme
MD5	0	133.7 MH/s	En hızlı
SHA-256	1400	27,838.6 kH/s ≈ 27.84 MH/s	MD5'ten ≈ 4.80× yavaş
bcrypt	3200	658 H/s	MD5'ten ≈ 203,191× yavaş

Bu makinede MD5 benchmarkı SHA-256'dan yaklaşık 4.80 kat, bcrypt'ten yaklaşık 203 bin kat daha yüksek deneme hızına ulaştı. SHA-256 da bcrypt'ten yaklaşık 42 bin kat daha hızlıydı.

2.5 Sorular 5.1-5.4

5.1 - Aynı sekiz parola üç yöntemde de küçük sözlük içinde bulundu. Benchmark sonuçlarım MD5 için 133.7 MH/s, SHA-256 için yaklaşık 27.84 MH/s ve bcrypt için 658 H/s oldu. MD5, SHA-256'dan yaklaşık 4.80 kat; bcrypt'ten yaklaşık 203 bin kat daha hızlı denenebildi. Bu ölçüm, parola saklamada kasıtlı yavaşlığın saldırganın deneme kapasitesini ciddi biçimde sınırladığını gösterdi.

5.2 - MD5 ve SHA-256 arasında hız farkı vardı; ancak ikisi de genel amaçlı hızlı özet fonksiyonları olduğu için küçük sözlükteki parolalar kolayca bulundu. SHA-256, MD5'e göre daha modern ve çarpışma direnci açısından güçlü olsa da parola saklama için özel olarak yavaşlatılmamıştır. Bu nedenle çevrimdışı parola tahminlerinde saldırgan saniyede milyonlarca deneme yapabilir; tek başına SHA-256 yeterli bir parola saklama yöntemi değildir.

5.3 - bcrypt'in yavaşlığı normal kullanıcı için tek bir parola doğrulamasında küçük ve kabul edilebilir bir gecikme oluşturur; saldırgan ise her tahminde aynı maliyeti tekrar ödemek zorundadır. Deneyimde benchmark hızı 658 H/s iken MD5 133.7 milyon H/s seviyesindeydi. Bu fark, kullanıcı deneyimini makul tutarken toplu parola tahmini maliyetini büyütür.

5.4 - Tuzsuz MD5'te aynı parolayı kullanan iki kullanıcının özeti de aynı olur. Bu durum hem parola tekrarını görünür kılar hem de önceden hesaplanmış tabloların/verilerin tekrar kullanılmasını kolaylaştırır. Salt, her kullanıcı için rastgele ve farklı bir değer ekleyerek aynı parola için farklı özetler üretir; böylece eşit parola → eşit hash ilişkisini ve ön-hesaplama saldırılarının verimini bozar.

2.6 İsteğe Bağlı John the Ripper Karşılaştırması

John the Ripper ile aynı MD5 listesi ve ders sözlüğü kullanıldı. Çıktıda "8 password hashes cracked, 0 left" sonucu görüldü. Kullanıcı adı alanı olmadığı için --show çıktısı "?:parola" biçiminde gösterildi. Bu adım +5 puanlık isteğe bağlı karşılaştırma olarak tamamlandı.

3. Hafta 3 - TLS, PKI ve Kontrollü MITM

3.1 PKI ve Sertifika Doğrulaması

gorev1_pki_uret.py betiği 232923044 öğrenci numarası ile çalıştırıldı. Üretilen lab.local sertifikası aşağıdaki özelliklerle doğrulandı:

- Subject: C=TR, O=Siber Guvenlik Ders, CN=lab.local
- Issuer: C=TR, O=Siber Guvenlik Ders, CN=Siber Güvenlik Ders Kök CA - 232923044
- SAN: DNS:lab.local, DNS:localhost, IP Address:127.0.0.1

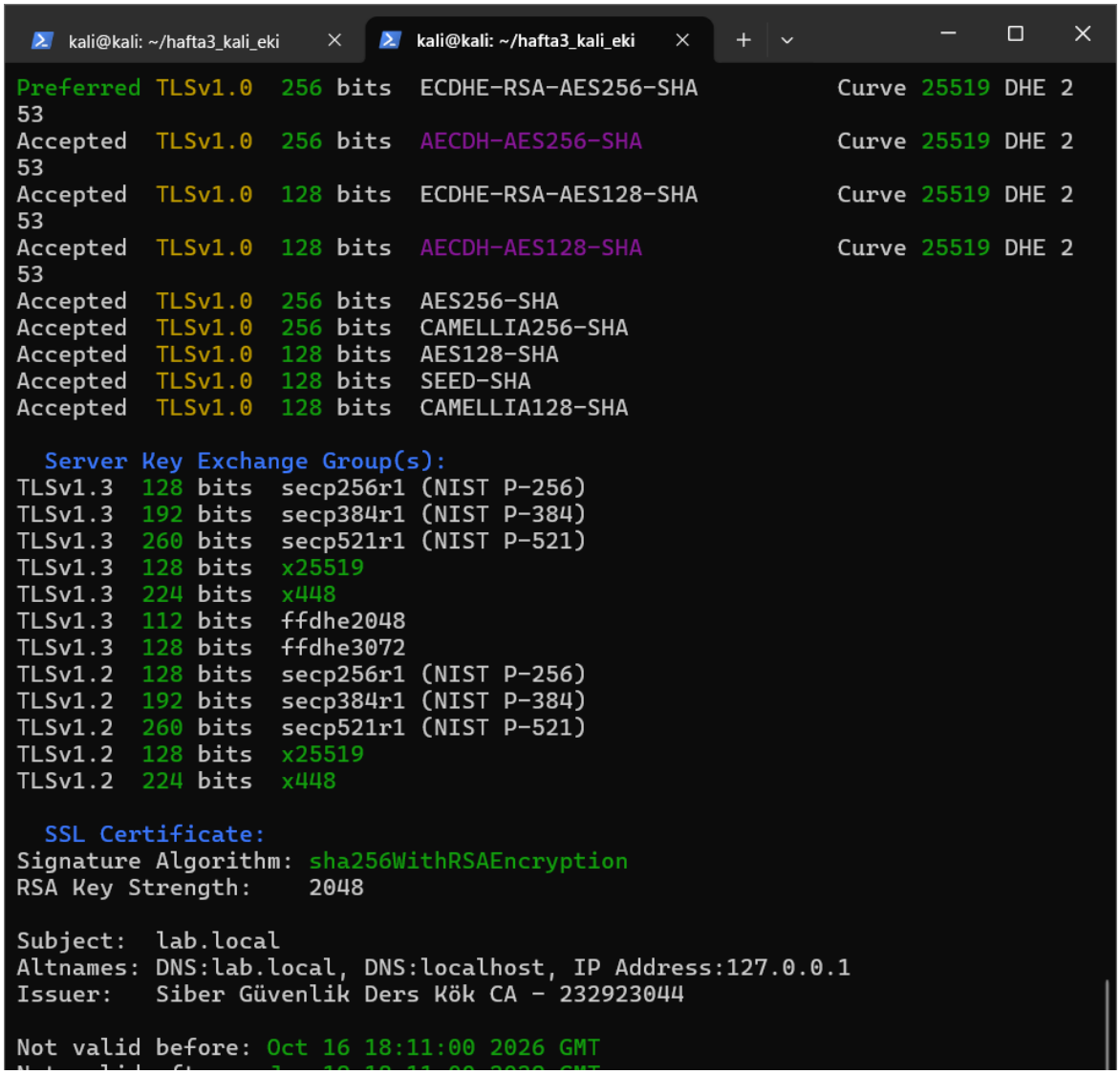
3.2 Güçlü TLS Sunucusu - sslscan

127.0.0.1:8443 üzerinde çalışan güçlü sunucuda yalnızca TLS 1.3 etkin bulundu. TLS 1.0, TLS 1.1 ve TLS 1.2 devre dışıydı. Tercih edilen şifre takımı TLS_AES_256_GCM_SHA384 oldu; TLS_CHACHA20_POLY1305_SHA256 ve TLS_AES_128_GCM_SHA256 da kabul edildi. Sertifika lab.local adına ve öğrenci numarasını içeren ders kök CA'sı tarafından imzalanmıştı.

```
SSLv2 disabled | SSLv3 disabled | TLSv1.0 disabled | TLSv1.1 disabled | TLSv1.2 disabled |
TLSv1.3 enabled
Preferred TLSv1.3: TLS_AES_256_GCM_SHA384
Accepted TLSv1.3: TLS_CHACHA20_POLY1305_SHA256, TLS_AES_128_GCM_SHA256
```

3.3 Zayıf TLS Sunucusu - sslscan

127.0.0.1:8445 üzerinde çalışan zayıf sunucunun gerçek sslscan çıktısında TLS 1.0, TLS 1.1, TLS 1.2 ve TLS 1.3 sürümlerinin tamamı etkin göründü. Görev yönergesinde modern OpenSSL sürümlerinde TLS 1.0/1.1'in kapalı kalabileceği notu vardı; ancak bu laboratuvar ortamında ölçülen sonuç aşağıdaki gibiydi ve rapora gerçek ölçüm yazıldı.

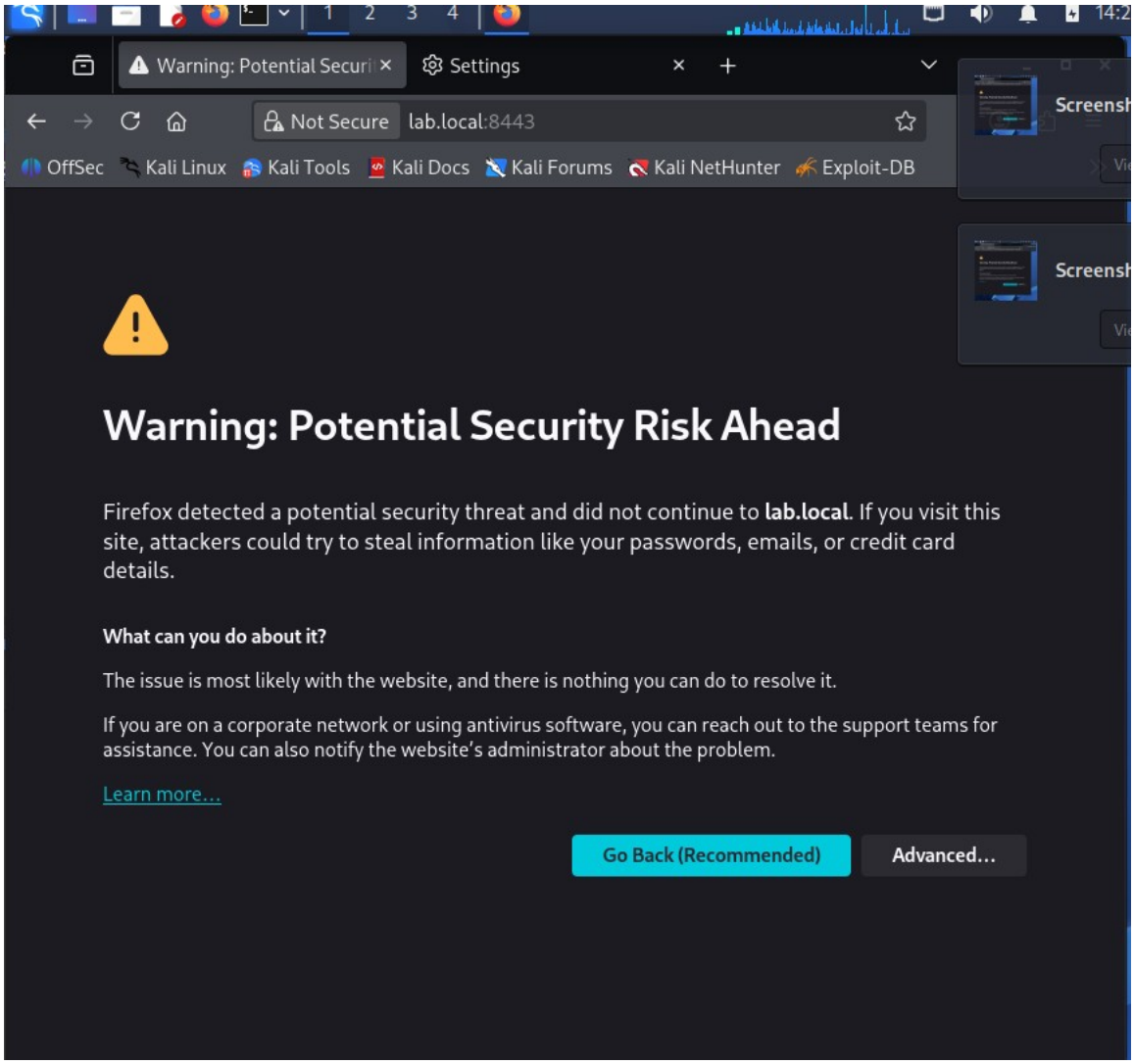


Şekil 3 - Zayıf sunucunun sslscan çıktısından eski TLS şifre takımları ve sertifika bilgileri.

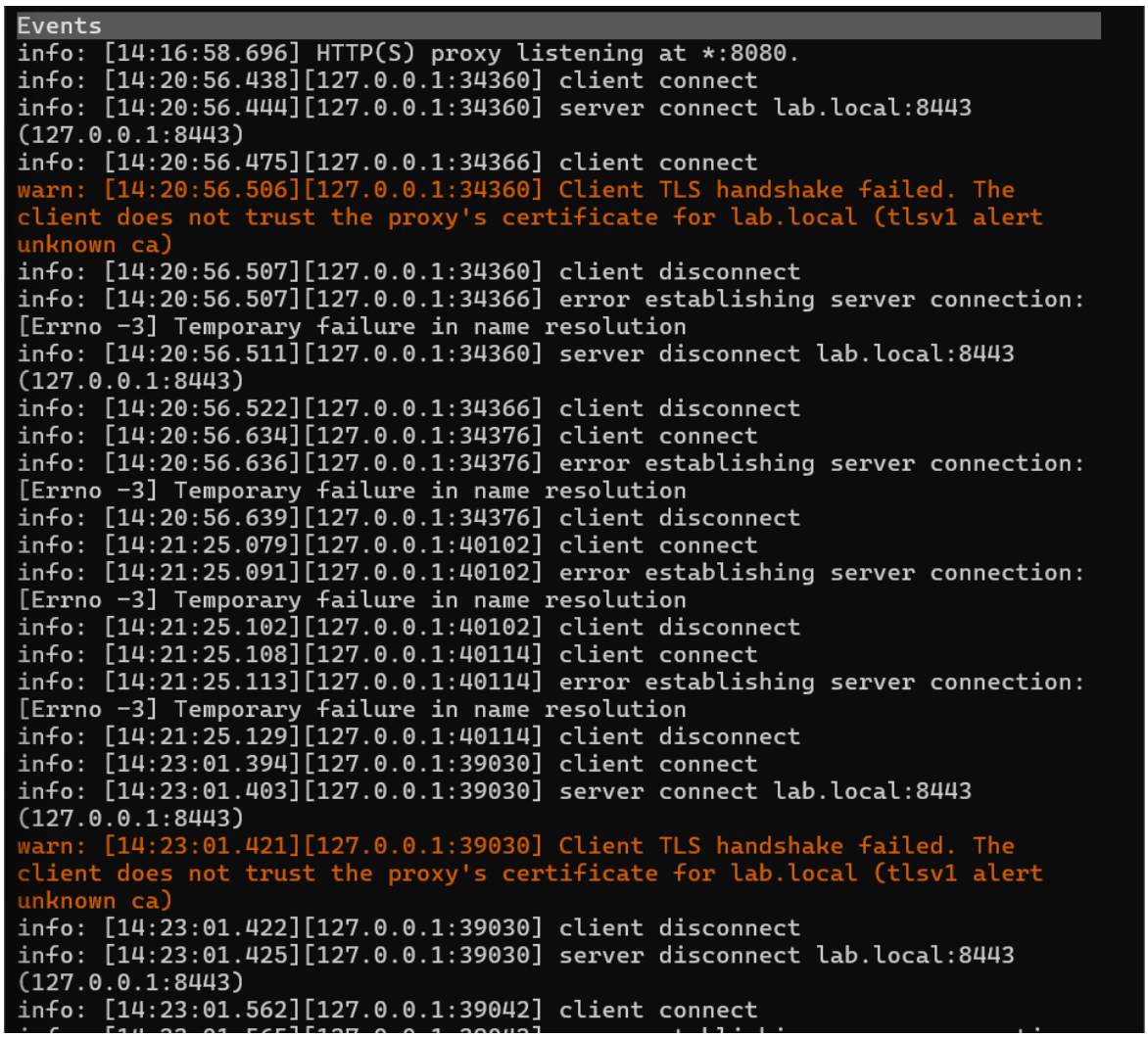
```
TLSv1.0 enabled | TLSv1.1 enabled | TLSv1.2 enabled | TLSv1.3 enabled
```

3.4 MITM - CA Güvenilmezken

Firefox, HTTP ve HTTPS proxy olarak 127.0.0.1:8080 mitmproxy'ye yönlendirildi. localhost/lab.local bağlantılarının proxy üzerinden geçmesi için network.proxy.allow_hijacking_localhost=true yapıldı ve no_proxies_on alanı boşaltıldı. mitmproxy CA'sı henüz Firefox tarafından güvenilir değildi.



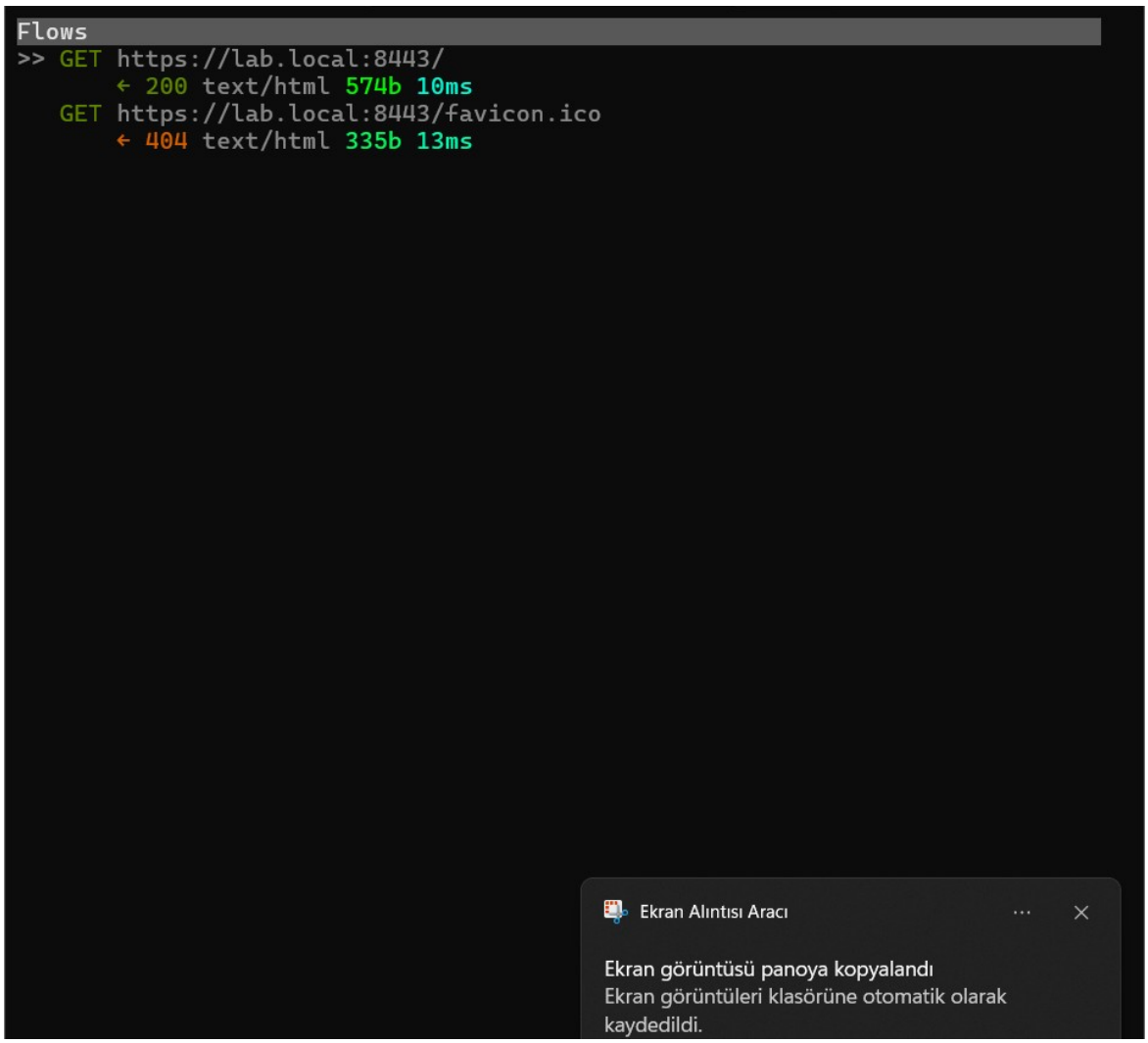
Şekil 4 - mitmproxy CA'sı güvenilir değilken Firefox sertifika uyarısı.



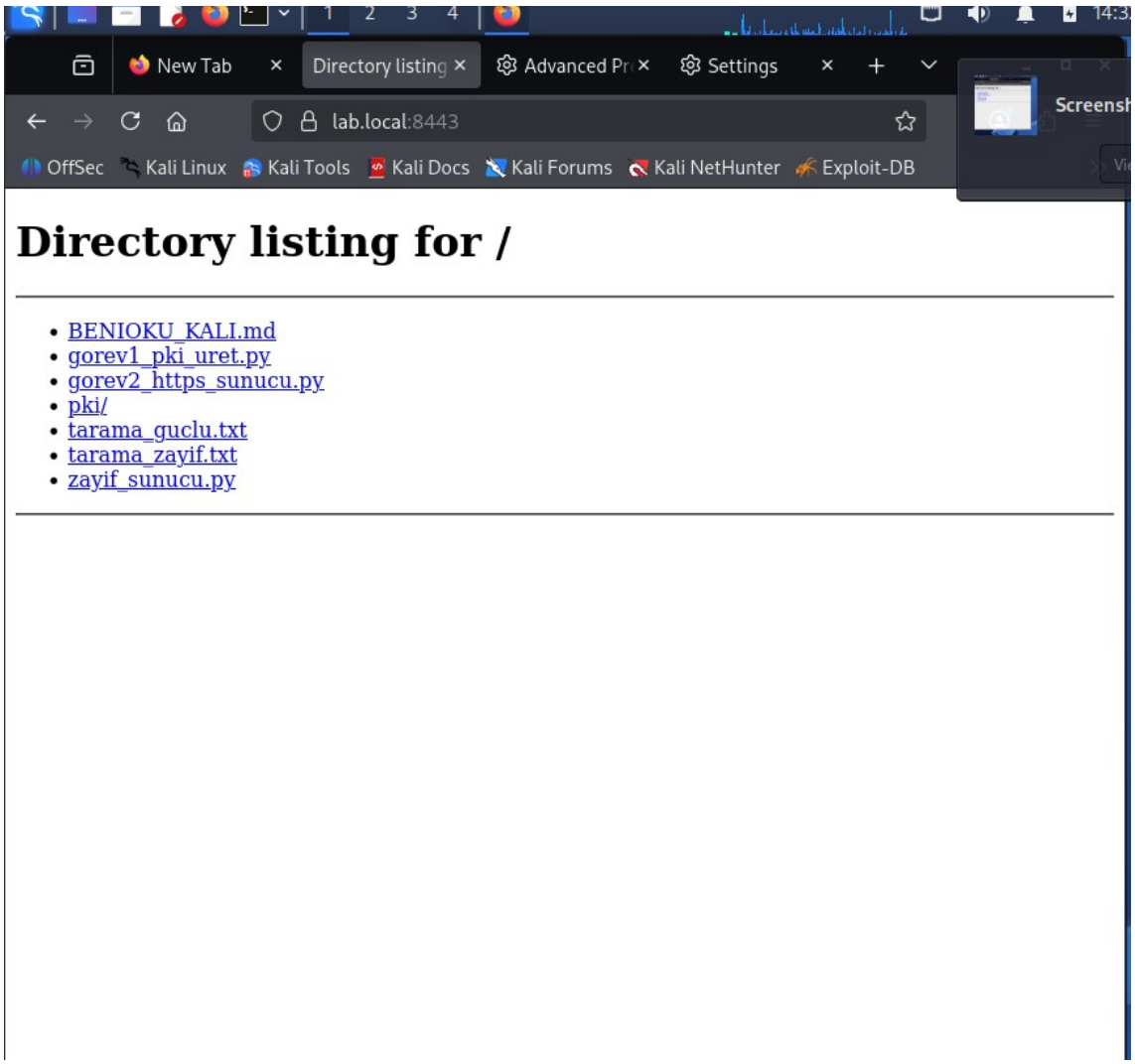
Şekil 5 - mitmproxy Events: "Client TLS handshake failed... client does not trust the proxy's certificate... unknown ca".

3.5 MITM - CA Güvenilir Olduktan Sonra

mitmproxy kök CA sertifikası Firefox Authorities listesine "identify websites" yetkisiyle eklendikten sonra aynı https://lab.local:8443 adresi uyarısız açıldı. mitmproxy akışında ana sayfa isteği 200 OK olarak görüldü; favicon isteği ise 404 döndü. Bu, laboratuvarın kontrollü MITM aşamasının çalıştığını doğruladı.



Şekil 6 - mitmproxy Flows: lab.local:8443 ana isteği 200 OK.



Şekil 7 - CA güvenilir olduktan sonra Firefox'ta lab.local:8443 sayfasının uyarısız açılması.

3.6 Sorular 6.1-6.4

6.1 - Güçlü sunucuda yalnızca TLS 1.3 etkin bulundu ve tercih edilen şifre takımı TLS_AES_256_GCM_SHA384 oldu. TLS_CHACHA20_POLY1305_SHA256 ve TLS_AES_128_GCM_SHA256 da kabul edildi. Yönergede karşılaştırılması istenen ana laboratuvardaki gorev2_istemci.py dosyası sağlanan ek görev paketinde bulunmadı; ayrıca Kali home, D:\SiberGuvenlikLab, Windows Downloads ve OneDrive Desktop konumlarında yapılan aramalarda da dosya bulunamadı. Bu nedenle sslscan sonucu ile gorev2_istemci.py çıktısı arasında doğrudan karşılaştırma yapılamadı; bu eksiklik raporda açıkça belirtilmiştir.

6.2 - Güçlü sunucu yalnızca TLS 1.3 kabul ederken zayıf sunucu taramasında TLS 1.0, 1.1, 1.2 ve 1.3 etkin görüldü. Bir sistem yöneticisi olarak TLS 1.0 ve 1.1'i kapatırdım; mümkünse yalnızca TLS 1.3 kullanırdım. Eski istemci uyumluluğu zorunluysa TLS 1.2 güçlü şifre takımlarıyla sınırlandırılabilir.

6.3 - mitmproxy CA eklenmeden önce Firefox, lab.local için proxy'nin sunduğu sertifikayı imzalayan kök CA'ya güvenmediği için TLS el sıkışmasını "unknown ca" ile reddetti. CA, Firefox'un

güvenilir Authorities listesine eklendikten sonra aynı sertifika zinciri güvenilir kabul edildi ve bağlantı uyarısız açıldı. Bu, bir kök CA'ya güvenme kararının o CA'nın imzaladığı site sertifikalarına da güvenmek anlamına geldiğini gösterir.

6.4 - Deneyde saldırganın trafiğin üzerinden geçtiği bir proxy konumuna ve tarayıcı tarafından güvenilen bir kök CA'ya sahip olması gerekiyordu. Gerçek bir bankada saldırgan normal koşullarda kullanıcının güvenilir kök CA deposuna kendi sertifikasını ekleyemez ve banka alan adı için geçerli bir sertifika üretemez. Sertifika Şeffaflığı (CT) sertifika üretimlerini görünür ve denetlenebilir hale getirir; CAA kayıtları ise alan adının hangi sertifika otoritelerinin sertifika verebileceğini belirtmesine yardımcı olur.

3.7 Temizlik ve Güvenli Kapanış

Güçlü ve zayıf HTTPS sunucuları Ctrl+C ile durduruldu. Görev yönergesi ayrıca Firefox proxy ayarının kapatılmasını, mitmproxy CA sertifikasının Authorities listesinden silinmesini ve network.proxy.allow_hijacking_localhost değerinin false'a döndürülmesini zorunlu kılar.

Teslim öncesi doğrulama: Bu rapor hazırlanırken sunucuların durdurulduğu ekran çıktısıyla doğrulandı. Firefox proxy/CA temizliğinin son GUI doğrulaması kullanıcı tarafında yapılmadan "proxy ayarını kapattım ve mitmproxy CA'sını sildim" beyanı kesinleşmiş sayılmamalıdır.

4. Sonuç

Hafta 2 deneyleri, genel amaçlı hızlı hash fonksiyonları ile parola saklamaya özel yavaş hash fonksiyonları arasındaki farkı doğrudan gösterdi. Aynı parola listesinde MD5 ve SHA-256 çok yüksek benchmark hızlarına ulaşırken bcrypt 658 H/s seviyesinde kaldı. Hafta 3 deneyleri ise güvenli TLS yapılandırmasının yalnızca modern protokollerle sınırlandırılmasının önemini ve bir kök CA'ya güvenmenin MITM açısından ne kadar kritik bir güven kararı olduğunu uygulamalı olarak gösterdi.

5. GitHub Teslim Notu

Görev yönergesi, üretilen parola özetleri/çözümlerinin rapor dışında paylaşılmamasını ve özel anahtarların korunmasını gerektirir. Bu nedenle GitHub deposunda ham ekip_md5.txt / ekip_sha256.txt / ekip_bcrypt.txt, potfile, pki/*.key veya mitmproxy CA özel anahtarları bulunmamalıdır. Rapor ekran görüntüler içerdiğinden depo tercihen PRIVATE oluşturulmalıdır.